

Clase 313 — Gestión del ciclo de vida de identidades (IAM empresarial)

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide — Dominio 5: Identity and Access Management 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Dominar cómo una organización gobierna las identidades de sus usuarios desde el alta hasta la baja: el ciclo **Joiner–Mover–Leaver (JML)**, el aprovisionamiento y desaprovisionamiento, los modelos de autorización (RBAC/ABAC/least privilege) y las **revisiones de acceso** periódicas. Es material central del dominio IAM de CISSP y de la gobernanza de identidad (IGA) que sostiene toda la seguridad de acceso.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Describir** las fases del ciclo de vida de la identidad y el flujo JML.
- 2. **Diferenciar** identificación, autenticación, autorización y accountability (IAAA).
- 3. **Comparar** DAC, MAC, RBAC y ABAC y elegir el modelo adecuado por escenario.
- 4. **Diseñar** una matriz de roles (RBAC) aplicando mínimo privilegio y separación de funciones.
- 5. **Planificar** campañas de recertificación de acceso y detectar *privilege creep*.
- 6. **Integrar** aprovisionamiento automatizado (SCIM/IGA) con RR. HH. como fuente autoritativa.

📖 Temas

#	Tema	Por qué importa
1	IAAA (los cuatro pilares)	Marco mental de todo control de acceso
2	Ciclo de vida de la identidad	El acceso debe seguir al estado laboral real
3	Joiner–Mover–Leaver	Las bajas y cambios mal gestionados son la mayor brecha
4	Aprovisionamiento / desaprovisionamiento	Automatizar reduce error y latencia
5	Modelos: DAC/MAC/RBAC/ABAC	Determina cómo se decide cada acceso
6	Mínimo privilegio y SoD	Limita el daño de una cuenta comprometida
7	Revisiones y recertificación de acceso	Corrige el privilege creep acumulado
8	Cuentas de servicio y no humanas	Suelen quedar fuera del ciclo y sin dueño

Definiciones y características

- **Identidad:** representación digital única de un usuario, dispositivo o servicio dentro del sistema. Característica: debe ser **única e inequívoca** (no cuentas compartidas).
- **IAAA:** Identificación (declarar quién eres), Autenticación (probarlo), Autorización (qué puedes hacer) y Accountability (registro de lo que hiciste). Marco base del dominio.
- **JML (Joiner-Mover-Leaver):** modelo del ciclo laboral — alta al ingresar, ajuste al cambiar de rol y baja al salir. Característica: cada evento debe disparar un cambio de acceso.
- **RBAC:** control de acceso basado en roles; los permisos se asignan a roles y los roles a personas. Escala bien y facilita auditoría.
- **ABAC:** control basado en atributos (usuario, recurso, entorno). Más granular y dinámico que RBAC; base de políticas contextuales (hora, ubicación, sensibilidad).
- **Mínimo privilegio:** cada identidad recibe solo los permisos que necesita para su función. Característica: reduce la superficie de una cuenta comprometida.
- **Separación de funciones (SoD):** ninguna persona controla un proceso crítico de extremo a extremo (p. ej. quien crea un pago no lo aprueba). Previene fraude y error.
- **Privilege creep:** acumulación de permisos que un usuario ya no necesita tras cambios de rol. Se corrige con recertificación periódica.

Herramientas y preparación

Clase de gobierno con laboratorio de diseño. Prepara:

- Hoja de cálculo para la **matriz de roles** y el registro de recertificación.
- Un directorio de referencia para ilustrar conceptos: Active Directory / Microsoft Entra ID, o el open source **Keycloak**, para ver grupos, roles y aprovisionamiento.
- El estándar **SCIM 2.0** (RFC 7643/7644) como referencia del aprovisionamiento automatizado.
- Opcional: una plataforma IGA de referencia (SailPoint, Saviynt, Microsoft Entra ID Governance) para entender campañas de acceso; basta con el concepto para el ejercicio.

Laboratorio guiado — Diseñar el ciclo de vida y una matriz RBAC

Sobre la empresa "**NovaSalud**" de clases anteriores.

1. **Fuente autoritativa.** Declara a RR. HH. como origen de verdad de la identidad: alta, cambio y baja se originan allí y se propagan a los sistemas (idealmente vía SCIM).
2. **Flujo Joiner.** Diagrama el alta: RR. HH. crea el registro → se genera la cuenta → se asignan roles por puesto → se habilita MFA → se notifica al usuario. Define el SLA (p. ej. listo el día 1).
3. **Flujo Mover.** Diseña el cambio de rol: al cambiar de puesto se **retiran** los permisos del rol anterior y se asignan los del nuevo. Evita el patrón "sumar sin restar" (privilege creep).
4. **Flujo Leaver.** Define la baja: deshabilitar (no borrar de inmediato) la cuenta el mismo día, revocar sesiones y tokens, transferir la propiedad de datos y programar el archivado.
5. **Matriz de roles RBAC.** Crea una tabla **Rol × Permiso** para al menos 5 roles (recepción, enfermería, médico, facturación, administrador de sistemas) y 8 permisos. Marca el acceso mínimo.
6. **Separación de funciones.** Identifica al menos un par de permisos incompatibles (p. ej. "crear proveedor" y "aprobar pago") y prohibelos en una misma persona en la matriz.
7. **Campaña de recertificación.** Define su alcance (accesos privilegiados y a datos **Restringido**), frecuencia (trimestral), aprobador (el manager) y qué pasa si no responde (revocación por defecto).

Documenta cómo se registra la evidencia.

8. **Identidades no humanas.** Añade una sección para cuentas de servicio: dueño asignado, rotación de credenciales y su inclusión en las revisiones.

Ejercicios

1. Dibuja el ciclo de vida completo de la identidad con los disparadores de cada transición.
2. Explica con un ejemplo la diferencia entre autenticación y autorización.
3. Convierte una lista de accesos individuales desordenados en un modelo RBAC de 4 roles.
4. Define 3 reglas de separación de funciones para un proceso de compras.
5. Diseña el flujo Leaver para un despido inmediato: ¿qué se hace en los primeros 15 minutos?
6. Propón una regla ABAC que RBAC no pueda expresar bien (p. ej. acceso solo en horario laboral y desde red corporativa).

Reto verificable

Entrega un **Manual de Gestión del Ciclo de Vida de Identidades** que contenga: los tres flujos JML con SLA, una matriz RBAC con mínimo privilegio, al menos dos reglas de SoD y el plan de una campaña de recertificación trimestral.

Criterio de aceptación: dado un caso — "una enfermera pasa a facturación y luego renuncia" — tu manual permite a un operador ejecutar Mover y luego Leaver indicando exactamente qué permisos se retiran, cuándo y quién lo aprueba, sin ambigüedad.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
La cuenta del expleado sigue activa semanas después	Leaver no automatizado. Conecta RR. HH. como fuente y deshabilita el día de la baja.
Usuarios con permisos de tres puestos anteriores	Privilege creep: Mover suma pero no resta. Retira los roles previos y recertifica.
Todo el mundo es administrador "por comodidad"	Se viola mínimo privilegio. Rediseña roles y separa lo privilegiado.
Cuentas de servicio sin dueño ni rotación	Quedan fuera del ciclo. Asigna propietario, rota credenciales e inclúyelas en revisiones.
Recertificación que todos aprueban sin mirar	<i>Rubber-stamping.</i> Muestra el uso real del acceso y revoca por defecto si no hay respuesta.
Cuentas compartidas de equipo	Rompen la accountability. Sustituye por cuentas individuales con roles.

Preguntas frecuentes

? ¿RBAC o ABAC? No es excluyente. RBAC es simple, auditable y escala para la mayoría de casos; ABAC añade granularidad y contexto (hora, ubicación, sensibilidad). Muchas organizaciones combinan roles como base y atributos para políticas finas.

? ¿Por qué deshabilitar y no borrar la cuenta al dar de baja? Para preservar la trazabilidad, cumplir retención de logs y permitir investigaciones. Se borra después, según la política de retención, tras transferir la propiedad de datos.

? ¿Cada cuánto recertificar accesos? Depende del riesgo: accesos privilegiados y a datos sensibles, al menos trimestralmente; el resto puede ser semestral o anual. Un cambio de rol siempre debe forzar una revisión puntual.

? ¿Las cuentas de servicio también entran en el ciclo JML? Sí, en su versión no humana: tienen un "alta" (creación con dueño), "cambios" (rotación de credenciales, cambio de permisos) y "baja" (desactivación cuando la app se retira).

Referencias

- (ISC)² — *CISSP Official Study Guide*, 9.^a ed., Dominio 5 *Identity and Access Management*.
- NIST SP 800-162 — *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*. <https://csrc.nist.gov/pubs/sp/800/162/final>
- RFC 7644 — *System for Cross-domain Identity Management (SCIM) Protocol*. <https://www.rfc-editor.org/rfc/rfc7644>
- NIST SP 800-53 Rev. 5 — familia de controles AC (Access Control) y IA (Identification and Authentication).
- CompTIA — *Security+ SY0-701*, dominio de arquitectura y operaciones (IAM).

Siguiente clase

Clase 314 - Federación, SSO, SAML y OpenID Connect